

Register now for your free, tailored, daily legal newsfeed service.

Register

Find out more about Lexology or get in touch by visiting our [About](#) page.

AI and privacy: analysis of the EDPB document “AI privacy risks & mitigations - LLMS”

LEXIA

Italy | April 14 2025

The EDPB document analyzes the privacy risks associated with LLMs and proposes an operational methodology for their mitigation. This contribution offers a critical reading of the text in light of current and upcoming regulations, and provides concrete guidelines for businesses and developers committed to the responsible adoption of generative AI.

Introduction

The advent of large language models (LLMs) represents one of the most disruptive transformations in the evolution of artificial intelligence. Thanks to their ability to understand, generate, and manipulate natural language, these systems are now employed across a wide range of contexts: from virtual assistance to automated text generation, from programming to decision support in medico-legal settings, and even integration into intelligent agents with operational autonomy.

Alongside the extraordinary opportunities offered by these tools, however, arise significant concerns regarding the protection of fundamental rights, particularly the right to personal data protection. By their very nature, LLMs rely on training processes involving the processing of massive volumes of data, often drawn from heterogeneous sources and sometimes containing information relating to identified or identifiable individuals. Moreover, the operating mechanisms of these models—based on statistical and probabilistic approaches—make it difficult, if not impossible, to fully control the content of the outputs generated or to ensure that personal data learned during training is not inadvertently reproduced.

In this context, the document prepared by the Support Pool of Experts on behalf of the European Data Protection Board (EDPB), titled “AI Privacy Risks & Mitigations – Large Language Models (LLMs)” (March 2025), represents a critically important contribution for guiding the activities of developers, providers, and users of LLMs in compliance with Regulation (EU) 2016/679 (GDPR) and the forthcoming AI Act.

The document goes beyond a theoretical overview of the main categories of privacy risks; it proposes an operational methodology for identifying, assessing, and mitigating the risks associated with LLMs, adopting an approach grounded in the principles of data protection by design and by default, data minimization, and accountability. It also includes a systematic review of technical and organizational measures recommended to reduce exposure to risk and outlines the implications arising from the distribution of roles and responsibilities among the various actors involved in the AI system lifecycle.

Recognition and classification of privacy risks in LLMS



The EDPB document offers an in-depth analysis of the privacy risks associated with large language models throughout the entire system lifecycle, structuring its examination across a variety of use cases and technical configurations. The first significant step consists precisely in the systematic categorization of the main risk types, which arise during the training phase, the inference phase (when the model is used to generate responses to user inputs), and the iterative update processes based on user feedback (fine-tuning / reinforcement learning).

Among the most common and significant risks are:

- unintentional retention of personal data in model weights, which can lead to its reappearance during inference (a phenomenon known as data leakage or regurgitation). This risk is particularly pronounced in large-scale models trained on uncontrolled general-purpose datasets, such as web-crawled sources (e.g., Common Crawl), which may contain identifiable data, including special categories as defined under Article 9 of the GDPR;
- inability to deterministically predict model outputs: given that LLMs are based on neural architectures and distributed attention mechanisms (transformers), their behavior cannot be fully verified in advance. This complexity hinders both the data protection impact assessment (DPIA) and the pre-emptive identification of risks;
- indirect processing of personal data through user prompts: even in the absence of an explicit data collection function, user-model interactions may involve the processing of personal information provided by the data subject or third parties, potentially establishing the deployer's responsibility under Article 4(2) GDPR;
- excessive retention of input/output data by the model provider, often for service improvement purposes, without a valid legal basis or without proper information provided to users (violating Articles 5, 13, and 14 GDPR). This issue is particularly relevant in LLM-as-a-Service models, where the end user has neither visibility nor control over data processing within the provider's infrastructure;
- incompatibility between the original processing purpose and the secondary use of data for fine-tuning: in the absence of a solid legal basis—such as valid consent or a properly balanced legitimate interest—using data collected during interactions to retrain the model may constitute a violation of the purpose limitation principle (Article 5(1)(b) GDPR);
- difficulty in ensuring data subject rights, especially the rights to erasure, restriction of processing, and objection: once personal data has been absorbed into the model—particularly through embedding or tokenization processes—it becomes technically complex to isolate, creating a gap between legal obligations (Article 17 GDPR) and the actual feasibility of compliance, with significant consequences for the principle of accountability (Article 5(2) GDPR);
- lack of transparency regarding algorithms and inferential logic: the document highlights how LLMs inherently function as “black-box systems”, making it difficult for users and data subjects to understand how the system works, which sources were used, and the rationale behind certain responses. This lack of clarity may directly conflict with Article 22 GDPR in cases of automated decision-making, especially when the model is used in HR, insurance, or credit contexts.

A key strength of the EDPB document lies in its ability to contextualize these risks across different architectural and contractual configurations of LLM systems, considering the growing adoption of multimodal models, agentic architectures, and orchestration processes involving both LLMs and Small Language Models (SLMs). Each technological evolution introduces new attack surfaces for data protection and requires a recalibration of the risk model—both in terms of probability and severity of potential impact.

It is also important to emphasize that privacy risks in LLMs are not only direct but also potential and future-oriented: many risks emerge over time, as models are integrated into more complex systems (e.g., AI agents) or combined with proprietary data sources, CRM systems, or internal knowledge bases. In this light, risk management must not be seen as a one-off task but as a dynamic, iterative process that accompanies the development and evolution of the LLM over time.

Privacy risk assessment in LLMS

One of the most relevant contributions of the EDPB document is the development of a structured methodology for assessing privacy risks related to large language models. This methodology is fully aligned with the general principles set out in Articles 5, 24, and 32 of the GDPR, and finds its operational cornerstone in Article 35, which governs Data Protection Impact Assessments (DPIA).

The document emphasizes that, given the potentially systemic nature of processing operations performed through LLMs, conducting a DPIA is not only recommended but, in most cases, mandatory—according to the WP29 “blacklist” (Opinion 248/2017), endorsed by the EDPB—which includes as high-risk processing activities those involving:

- the innovative use or application of new technological solutions;
- large-scale processing;
- automated processing with significant effects on data subjects.

All of these elements are, in fact, structurally present in LLM systems, especially when used in user-facing contexts or in support of critical business decisions.

1.1 From risk identification to risk estimation: a multidimensional matrix

The proposed methodology is structured around three main levels:

- **risk identification**, through mapping of data flows across the LLM lifecycle (collection, training, inference, logging, fine-tuning, updates, and decommissioning). This exercise must include both upstream data (training sets) and downstream data (user inputs/outputs and feedback). It is essential at this stage to clearly define the data categories, usage contexts, and the actors involved (controllers, processors, third-party providers, end users, etc.);
- **estimation of the likelihood of risk occurrence**, based on empirical criteria including: the quality of data sources, presence of filters or de-identification mechanisms, the type of architecture used (e.g., decoder-only or encoder-decoder models), access modality (on-premise, SaaS, API), available documentation, and whether the provider has obtained certifications or passed audits;
- **assessment of impact severity**, which must consider not only the nature of the data potentially involved (e.g., health, judicial, biometric data), but also the model’s use context, the system’s degree of decision-making autonomy, and the concrete possibility of re-identifying data subjects;

The expected output of this evaluation is a risk classification, which the document suggests representing in a matrix format (low/medium/high by combining probability and impact). This serves as a practical tool to guide subsequent choices regarding mitigation measures and residual risk acceptance.

1.2 DPIA, accountability, and the model lifecycle

One of the most incisive observations in the document is that, in the LLM context, the DPIA cannot be treated as a one-time and static compliance exercise. Instead, it must evolve as a tool for dynamic privacy governance. Any modification to the model—whether architectural (e.g., integration of agentic modules or SLMs), functional

(new use cases or data sources), or organizational (provider change, migration from on-premise to SaaS)—requires an update of the impact assessment.

In this regard, the EDPB calls for integrating the DPIA with risk management tools and practices, including:

- periodic reviews of security controls (Article 32 GDPR);
- system log monitoring for audit and anomaly detection purposes;
- documented procedures for handling residual risk (acceptance, transfer, further mitigation);
- systematic involvement of the DPO during development, testing, and deployment phases.

It is worth recalling the consistent stance of the Italian Data Protection Authority, which states that “where the system is capable of producing significant effects on the rights and freedoms of natural persons, the DPIA is not only mandatory, but foundational to the entire accountability framework” (cf. Decision No. 1012 of 21.12.2023, on AI systems in the HR domain).

1.3 Integration between DPIA and AI risk assessment

Finally, the EDPB document anticipates one of the key pillars of the AI Act: the obligation—applicable to high-risk systems—to conduct an AI Risk Assessment under Articles 9 and following, which is distinct from but partially overlapping with the DPIA.

The message to businesses is clear: start adopting a unified risk assessment methodology now, one that satisfies the requirements of both legal frameworks. In particular, this implies:

- mapping the AI system not only for data protection purposes, but also in terms of safety, robustness, accuracy, and transparency;
- linking each privacy risk to a verifiable technical control (e.g., output filtering, retention policies, anonymized metadata);
- preparing documentary evidence that can be reused during inspections, including in a multi-regulatory compliance context.

Controllers, processors, and others roles between the GDPR and the AI Act

One of the most complex issues in applying the GDPR to systems based on large language models is the identification of the parties who, in various capacities, participate in the design, development, delivery, customization, or use of the model. The EDPB document addresses this issue with a case-based approach, distinguishing roles based on the different service delivery models and the architectural configuration of the systems.

In particular, there are at least three levels of actors who may assume distinct (or sometimes overlapping) roles in the data processing chain:

- model provider: develops the LLM, trains it, and makes it available—typically via API—for use by third parties;
- deployer (integrator user): configures and integrates the model into their own systems (e.g., enterprise chatbots, virtual assistants), defines its purpose, and controls its parameters;
- end user: interacts with the system through prompts, potentially providing personal data of their own or of others.

1.4 LLM-as-a-Service: joint controllership or delegated responsibility?

In the most common scenario currently on the market—using a model in LLM-as-a-Service mode (e.g., GPT-4 or Claude integrated via API into a web or mobile application)—the key question is whether the provider should be considered a separate controller, a processor, or a joint controller together with the deployer.

The EDPB document acknowledges that the answer depends on a case-by-case assessment, taking into account the following factors:

- who determines the purposes of the processing? If the deployer defines the purpose of the model’s use (e.g., customer support, profiling, medical assistance), they will generally qualify as the controller;
- who determines the means of processing? If the provider exercises autonomous control over the operational means (e.g., storage of prompts, use of data for fine-tuning, inferential logic), they may qualify as a separate controller, even if “downstream”;
- is there a contractual clause defining the roles? The EDPB clarifies that contractual clauses are relevant but not decisive: the substance of the relationship must be considered.

In practice, a mixed configuration is increasingly common, where:

- the deployer acts as the controller for user data processing via their service;
- the provider is a separate controller for their autonomous use of data for training, logging, and model improvement;
- both parties assume informational and contractual obligations (under Article 26 GDPR) if the processing is joint or interdependent.

In this context, the qualification of roles is not only a legal matter but also one of data governance: it is necessary to establish who collects the data, who stores it, who governs secondary uses, and who is responsible to data subjects.

1.5 Responsibility in agentic models and orchestrated systems

A particularly innovative—and still partly unexplored—area from a regulatory standpoint is that of AI agents: autonomous systems capable of interacting with external environments, making decisions, planning, and acting according to predefined goals, where the risk of loss of control is at its highest.

The EDPB document stresses that, in agentic systems based on LLMs, responsibility must be traced back to the organization that orchestrates the agent’s behavior, by defining its scope of action, decision rules, and external interfaces. This organization must (i) implement adequate security measures (Art. 32 GDPR); (ii) assess the systemic risks arising from automated decisions (Art. 22); (iii) define in advance the escalation channels and mechanisms for human oversight.

The AI Act, in Articles 28 and following, introduces a new actor category— the “deployer” of the AI system — who may coincide with the GDPR controller but also carries distinct obligations (e.g., audit, monitoring, event logging). This reveals the clear need to harmonize the two regulatory frameworks into a coherent responsibility allocation system.

1.6 Contractual and operational solutions

In light of the above, the EDPB document recommends the adoption of contractual and organizational tools aimed at:

- clearly defining privacy roles in provider–deployer relationships, referring where appropriate to standard EDPB models (e.g., Data Processing Agreement, Joint Controller Agreement);
- mapping processing activities in the GDPR records of processing;

- introducing mutual notification obligations in case of data breaches or data subject requests;
- establishing rules for retention, anonymization, or pseudonymization of prompts;
- providing for a shared AI interaction log (as per Article 29 of the AI Act) and a system for tracking automated decisions.

In summary, within the world of generative AI, it is no longer sufficient to simply identify “who is the controller”; instead, it is necessary to structure a shared accountability network, with explicit, verifiable obligations proportionate to the level of risk.

Risk mitigation measures

In the “AI Privacy Risks & Mitigations – LLMs” document, the EDPB’s Support Pool of Experts dedicates significant attention to identifying concrete and proportionate measures for mitigating privacy risks, tailored to the specific features of large language models. This approach aligns fully with the principle of privacy by design and by default (Art. 25 GDPR), and also extends to the AI governance framework outlined in the AI Act, particularly Articles 9, 17, 28, and 29.

2.1 Technical measures: from filtering to unlearning

Technical measures represent the first line of defense against risks arising from unlawful processing, data leaks, or unintentional exposure of personal data. Among the most effective, and already implemented by several providers in the market, are:

- **data filtering and curation in training datasets:** this involves the pre-selection of “low-risk” data sources (e.g., technical documentation, open-access sources with appropriate licenses) and the removal of content that may include personal information, such as email addresses, tax codes, or non-anonymized social media and court archive texts.
- **prompt and output filtering:** these are automatic filters that detect (and block) the input of potentially personal or sensitive data in prompts, as well as the generation of output containing identifiable patterns. Filters can operate at lexical, semantic, or syntactic levels and may be enhanced with NLP classification or Named Entity Recognition (NER) technologies.
- **machine unlearning:** the EDPB promotes the use of techniques allowing a model to selectively “forget” previously learned personal data upon the data subject’s request. Although these solutions are still evolving, promising approaches include SISA (Sharded, Isolated, Sliced and Aggregated Training) and methods based on distillation or low-impact re-training.
- **retrospective logging minimization:** this involves minimizing the data recorded in system logs, favoring aggregated or pseudonymous identifiers, and setting short data retention periods. This is aligned with Art. 5(1)(e) GDPR (data minimization and storage limitation) and Art. 29 AI Act (event logging and traceability).
- **Retrieval-Augmented Generation (RAG):** this architecture separates a system’s updated knowledge from the LLM’s static “memory,” using an external, queryable database in real time. This reduces the risk of personal data being structurally memorized by the model and enables more agile management of rights under Arts. 15–22 GDPR.

2.2 Organizational measures: accountability, processes, and internal controls

In addition to technical measures, the document highlights the importance of organizational interventions to ensure consistent and well-documented risk governance. Notable measures include:

- **definition of internal policies for LLM use:** Any organization adopting or integrating LLMs should establish a dedicated policy regulating usage methods, authorizations, operational limitations, and

prohibited use cases;

- staff training: Those interacting with LLMs (e.g., customer service, marketing, HR) must receive specific training on privacy risks, best practices for prompt management, and the obligation to avoid entering personal data without authorization;
- periodic audits of model behavior: Red-teaming or adversarial testing programs are recommended to assess whether the LLM might disclose information learned during training. These audits should be documented, repeatable, and integrated into the organization's risk management processes.
- interaction logging: Although not mandatory under the GDPR, maintaining logs of interactions (anonymized, where possible) can help detect misuse, improve system quality, and track potential violations;
- DPO designation and involvement in AI processes: The Data Protection Officer must be involved from the LLM selection and integration stage, with particular focus on DPIA preparation, user information disclosures, and responses to rights requests.

2.3 Contractual measures: risk management in the provider–deployer relationship

The EDPB document emphasizes how, in the relationship between the provider and deployer of LLMs, contractual measures play a crucial role in ensuring responsible privacy risk management. It is essential, first and foremost, to clearly formalize the roles of the parties: if the provider acts as the data processor, a Data Processing Agreement under Article 28 of the GDPR is necessary; in the case of joint controllership, an agreement under Article 26 is required to govern the purposes, responsibilities, and operational modalities.

Special attention should be given to the inclusion of clauses that regulate the retention of prompts, the use of data for fine-tuning, and the potential reuse of user feedback, establishing clear and verifiable limits. It is also recommended to include audit clauses in favor of the deployer, and to request from the provider compliance attestations or certifications, such as ISO/IEC 42001 or SOC 2 reports.

These contractual provisions, if well-structured, contribute to making the principle of accountability effective and ensuring that the use of LLMs is framed within a solid and documentable risk governance context.

Towards a sustainable, transparent, and compliant generative AI

The EDPB document provides an important European reference for evaluating and mitigating privacy risks associated with LLMs, but it cannot be read in isolation. Even outside the European Union, the United States, the United Kingdom, and Canada are building distinct – and partly complementary – approaches to regulate the responsible use of generative artificial intelligence.

In the United States, the Executive Order on AI has launched a more structured regulatory path, strengthened by the active role of the FTC and the voluntary framework of NIST; the focus is primarily on security, transparency, and human oversight. In the United Kingdom, however, a gradual and pro-innovation approach has been chosen, based on five general principles and guidance from sector authorities, with the ICO at the forefront in providing practical guidelines. Finally, Canada is preparing for the introduction of AIDA, while its supervisory authorities are already publishing recommendations and conducting investigations on the use of LLMs.

In this evolving context, European operators must also equip themselves by adopting solid responsibility and prevention practices from the outset. LLM providers are advised to carefully document the model's lifecycle, implement effective filtering measures, evaluate unlearning techniques, and strengthen audit mechanisms. Companies adopting these models should establish clear internal policies, assess the need for a DPIA, and train staff, limiting the inclusion of personal data in prompts. As for DPOs and consultants, it is essential to guide these choices with a strategic vision, integrating privacy governance and AI risk management.

International experience shows that the full value of LLMs can only be realized if supported by a robust legal and organizational framework. Ultimately, the challenge for operators today is not whether to comply with regulations, but how to do it well, anticipating risks and leveraging compliance as a trust and competitiveness driver; because only AI that respects rights will be truly useful, reliable, and ready for the future.

LEXIA - Aurora Agostini, Giulietta Minucci, Giovanni Lombardi and Alessandro Carlini

Visit our **website**

Interested in contributing?

Get closer to winning business faster with Lexology's complete suite of dynamic products designed to help you unlock new opportunities with our highly engaged audience of legal professionals looking for answers.

Learn more

Resources

Daily newsfeed | Panoramic | Research hubs | Learn | In-depth | Lexy Find | Scanner |

Contracts & clauses

Lexology Index

Find an expert | Reports | Research methodology | Submissions | FAQ | Instruct Counsel |

Client Choice 2025

More

Lexy AI | About us | Legal Influencers | Firms | Blog | Events | Popular | Lexology Academic |

Lexology Talent Management

Legal

Terms of use | Cookies | Disclaimer | Privacy policy

Contact

Help centre | Contact | RSS feeds | Submissions

[Login](#) | [Register](#)

Search Lexology

 Follow on X |  Follow on LinkedIn



© Copyright 2026 LBR trading as Centellic